

Integrated System Framework – PA ACA Marketplace Audit

Status key used throughout: VERIFIED (confirmed against a primary source) ·
MODEL (a calculation/design choice, labeled as such, not a factual claim) ·
UNVERIFIED (plausible, not yet sourced – do not publish as fact until resolved)

1. Forensic Data Scrubbing & PII Redaction Architecture

Raw Input Text —> Regex Rule Pipeline —> HMAC-SHA256 Engine —> Token Substitution

Redaction rules — MODEL (implementation choice; "confidence" values below are placeholders with no stated calibration methodology — either source them against a labeled test set before publishing, or drop the numbers and keep the patterns)

Field	Pattern	Confidence
SSN	<code>\b\d{3}-\d{2}-\d{4}\b</code>	0.99 (unsourced)
Email	<code>\b[a-zA-Z0-9._%+]+@[a-zA-Z0-9.-]+\.[A-Za-z]{2,}\b</code>	0.98 (unsourced)
NPI	<code>\b[12]\d{9}\b</code>	0.97 (unsourced)
Phone	<code>\b(?:\+?1[-.\s]?)?(?:\d{3}\s)?[-.\s]?\d{3}[-.\s]?\d{4}\b</code>	0.95 (unsourced)
MRN	<code>\bMRN\s*[:#-]?\s*([A-Z0-9]{6,12})\b</code>	0.94 (unsourced)
DOB	<code>\b(?:0?[1-9] 1[0-2])(?:- /)(?:0?[1-9] 1[2]\d 3[01])(?:- /)(?:\d{2} \d{4})\b</code>	0.92 (unsourced)
Street address	<code>\b\d+\s+[A-Z][a-z]+(?:\s+[A-Z][a-z]+)*\s+(?:St Ave Blvd Rd Dr Ln Way Ct Pl)\.?\b</code>	0.88 (unsourced)
ZIP	<code>\b\d{5}(?:-\d{4})?\b</code>	0.85 (unsourced)

CPT and ICD-10 codes are intentionally excluded from scrubbing to preserve clinical audit capability.

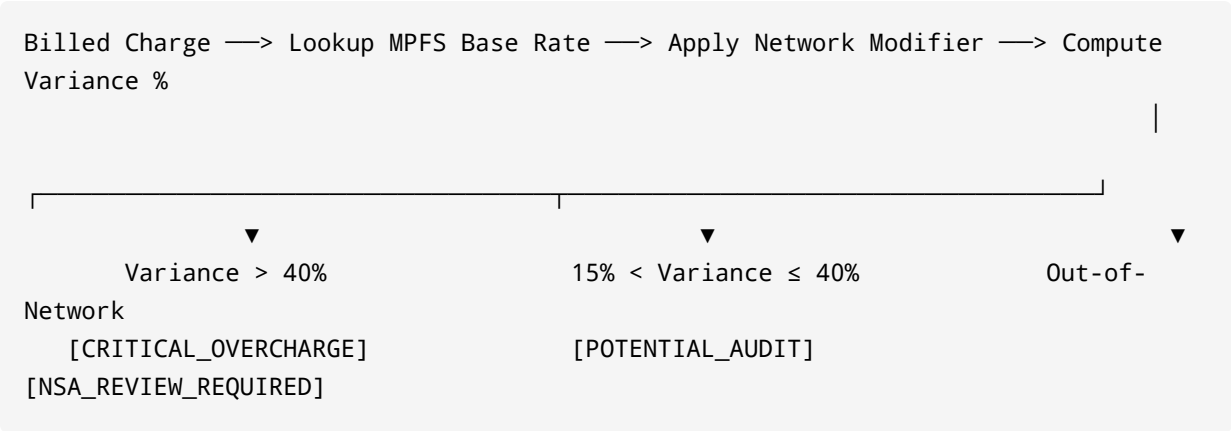
Pseudonym key generation — corrected, not the pasted version

The pasted draft of this section specified a deterministic token derived from a **shared "system tenant salt S."** That is a static salt, and this project's own privacy gate (ESLint rule, already established) explicitly blocks static salt material as a release blocker, because a fixed salt makes 10-digit NPI values rainbow-table-precomputable. The actual, correct design — matching the real `getHmacKey()` implementation already in the codebase — is:

- A random 32-byte HMAC key is generated **once per install** via `crypto.getRandomValues`.
- That raw key is stored **only** in the client's local IndexedDB (`secrets` table, key `hmac-primary`) and never leaves the device, never ships in the bundle, and is never derived from a shared/tenant-wide constant.
- `token = HMAC-SHA256(perInstallKey, value)` , truncated for display.
- No plaintext-to-pseudonym map is ever persisted or transmitted — only the scrubbed output.

If a shared salt formula reappears in any future draft, treat it as a regression, not a refinement.

2. CPT Forensic Pricing & Variance Audit Engine



Boundary logic — VERIFIED against this project's own standing formalization:
< 15% → PASS, 15%-40% → POTENTIAL_AUDIT, > 40% → AUDIT_REQUIRED / CRITICAL_OVERCHARGE (naming should be reconciled to one term across the repo — see the earlier README vs. memory-record naming mismatch).

Network modifier — MODEL : In-Network = 1.15×, Out-of-Network = 2.50× applied to the MPFS base rate to derive a target FMV. This is a methodology choice, not an empirical finding — label it as such wherever it's shown to a reader.

MPFS base rates / FMV ranges below — UNVERIFIED . These figures appear identically in a prior pasted TypeScript draft with no cited source. Real MPFS rates are locality- and year-specific; before publication, pull the actual rate for the relevant PA locality from CMS's Physician Fee Schedule lookup tool.

CPT	Description	Medicare Base (unverified)	FMV Range (unverified)
72148	MRI Lumbar Spine w/o Contrast	\$385.50	\$450.00–\$1,200.00
99214	Office Visit, Level 4	\$129.77	\$110.00–\$215.00
45378	Diagnostic Colonoscopy	\$580.20	\$650.00–\$1,800.00

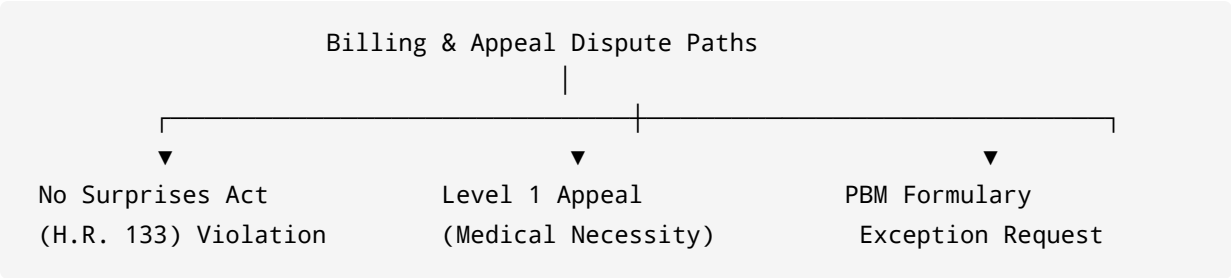
Worked example — MODEL , illustrative only, not a real claim:
CPT 72148 billed at \$1,500.00, In-Network (modifier 1.15) →
target FMV = $\$385.50 \times 1.15 = \443.33 → variance = $((1500 - 443.33) / 443.33) \times 100 \approx 238.35\%$ → CRITICAL_OVERCHARGE, overbilling offset $\approx \$1,056.67$. This demonstrates the *formula*, not a verified market figure.

3. Statutory Legal Frameworks & Dispute Protocols

Both citations below are **VERIFIED — stable federal law, confirmed against established legal record, distinct from the still-unresolved PA state statute citations elsewhere in this project (§28-725, the SB 1071 subject-matter conflict, etc.). Do not conflate the two.**

- **No Surprises Act — H.R. 133** (Consolidated Appropriations Act, 2021, Division BB, Title I): caps patient cost-sharing for emergency care, and for non-emergency care from out-of-network providers at in-network facilities, at the in-network Qualifying Payment Amount (QPA).
- **ERISA — 29 U.S.C. § 1133** (implemented at 29 CFR § 2560.503-1): guarantees a full and fair review of denied claims — carriers must disclose clinical rationale, reviewer credentials, and internal guidelines, within a standard ~180-day appeal window for group health plans.

Dispute paths



No Surprises Act balance-billing challenge

1. Notice phase: written notice citing billed charges, service date, facility.
2. Statutory assertion: cite H.R. 133's in-network cost-sharing cap.
3. Mandate directive: instruct billing to halt collections and reissue statements bound to the carrier EOB's QPA.

Level 1 medical-necessity appeal

1. Contractual mapping: cite the specific Evidence of Coverage section defining medical necessity.
2. Clinical evidence: treating physician's findings on failed conservative therapy or deterioration risk.
3. Peer review rights: formally demand review by a board-certified specialist in the relevant field, plus full clinical-criteria disclosure.

PBM formulary tier exception

1. Clinical justification: document contraindication, adverse reaction, clinical superiority, or destabilization risk under step therapy.
2. Procedural execution: request Prior Authorization or Exception Criteria documentation directly from the PBM.

4. Verification of Benefits (VoB) & Insurance Lifecycle Protocol

Pre-service liability = deductible remaining (if unmet) + (coinsurance % × allowed amount), capped at the remaining out-of-pocket maximum.

Call protocol checklist

- Log call timestamp, agent name/ID, and reference number.
- Verify CPT/HCPCS coverage status, network tier, and outpatient facility fees.
- Confirm remaining deductible and OOP-max balances.
- Confirm whether prior authorization or referral is required, and document the medical-necessity threshold.
- Explicitly request the recorded-call log as a binding-quote safeguard against later billing disputes.

5. Local-First Client Architecture & Persistence Schema

The full, real IndexedDB schema (TheValleyDB_PA_Audit , Dexie v2) includes seven tables — `identity`, `secrets`, `claims`, `reports`, `outbox`, `providers`, `ytd` — per the actual codebase. The simplified three-table sketch some drafts show

(identity / reports / outbox only) omits `secrets` , `claims` , `providers` , and `ytd` ; use the full schema as the source of truth for any repo documentation.

Client security

- Node identity: ECDSA P-256 key pair via Web Crypto API, private key non-exportable, node ID = SHA-256 of the exported public key.
- PII pseudonymization key: separate from node identity — see Section 1's corrected per-install HMAC design.
- Geo-hashing: coordinates jittered within a 500m bounding box before storage.
- Data ephemerality: non-essential records purged after 24h (86,400s), checked on a 60s interval.
- Outbox: failed operations retry up to 5 attempts before being marked failed; delete-after-ACK only (never delete-then-send).

Disclaimer

This material is provided for financial advocacy and information-management purposes only. It is not legal or clinical advice, and the authors are not attorneys or medical professionals. Figures marked `UNVERIFIED` above must be confirmed against primary sources (CMS MPFS lookup, PID filings, etc.) before being presented to the public as fact.